WEBSITE DEVELOPMENT / DOCUMENT 07 — ANSWERS

Technical Architecture

Completed questionnaire: components, platform choices, security and operations

PROJECT / WEBSITE	Radiant Institute of Professional Studies (RIPS), Sheikhupura — rips.edu.pk
PREPARED BY	Sarosh (website developer)
DATE / VERSION	17 October 2026 / v1.0 draft answers — for review
COVERAGE	38 questions · 8 sections · architecture diagram · 9 decisions (ADR-01 to ADR-09) · 12-component inventory
INPUTS	Doc 01 PVS answers (draft v0.1) · Doc 02 PRD answers (draft v1.0) · Doc 03 SRS answers (draft v1.0) · Docs 04–06 answers

How to read this. References use the earlier documents' IDs: **PVS Q**n (Doc 01), **PRD Q**n (Doc 02), SRS IDs such as **B-01**, features **FEAT-001…006** and open decisions **OD-01…18** (Doc 03). **Not Decided** names its owner. **Not Applicable** gives a reason. *(proposed)* marks a recommendation the approver must confirm. Doc 07 asks not to preselect vendors without evidence: provider names below are options to compare, and only choices backed by the requirements are marked **Proposed**.

CONTENTS

Sections and worksheets

A	Inputs & system boundary	5 questions
B	Application shape & components	5 questions
C	Platform & delivery choices	5 questions
D	Data, files & integration	5 questions
E	Identity & security	5 questions
F	Performance, resilience & observability	5 questions
G	Quality & maintainability	5 questions
H	Decision & acceptance	3 questions
W	Architecture diagram (proposed)	
W	Architecture decision register (ADR-01 to ADR-09)	
W	Component & integration inventory	

A. Inputs & system boundary

01. Which approved requirements and journeys drive the architecture, and which are still unresolved?

> **Drivers:** mostly read-only public content (SRS B-03); one visitor input, the enquiry (FEAT-003); staff publishing without a developer (FEAT-006); security after the hack (SRS O-01); speed on mobile data (SRS P-03); 99.5% availability (P-06); low running cost and one developer (SRS B-08). Journeys J1–J10 (Doc 04).
>
> **Unresolved:** host (OD-03), email (OD-04), editing tool (OD-05), form handling (OD-06), budget (OD-12), legal review (OD-15). None of the docs approve phase 2 features yet, so the design avoids accounts and payments.

02. Which capabilities belong in the browser, application server, background jobs or external services?

Layer	Capabilities
Browser	Show pages; filter lists; field validation; WhatsApp/call links; spam-check widget
Application server	**Not Applicable** — no always-on server. A small serverless function handles enquiry submission only
Build step	Turns content files into pages, sitemap, notice archive moves, intake badges (rebuilt daily)
Background jobs	Daily scheduled rebuild (dates/archiving); weekly sheet export; optional daily enquiry summary
External services	Hosting/CDN, CMS sign-in, Google Sheet, email, spam check, analytics, maps, WhatsApp, uptime monitor

03. Is this a static site, CMS site, dynamic application or combination? What specific needs justify the choice?

> **Combination (proposed, ADR-01):** a static site built from content files, edited through a Git-based CMS, with one serverless function for enquiries. Justification: visitors only read content and send one form; static pages are fast and have little to hack; staff still get a simple editor; costs stay near zero; one developer can maintain it. A full dynamic application would only be justified by phase 3 student accounts.

04. Which existing systems, data or deployment constraints must the new site work with?

> - Domain rips.edu.pk at DOMAIN.pk (.pk registry); registrar access needed for DNS.
> - Existing institute email, if any runs on Hostinger: MX records must be recorded first (PVS Q58).
> - No old data can be imported (no Hostinger access).
> - Development on the developer's computer in VS Code.
> - Institute social accounts as sources of photos and video.

05. What assumptions about traffic, content size, geographic reach and growth need validation?

> Assumptions (SRS P-01): 100–300 visits a day, 1,000–3,000 at admission peaks, 100 concurrent; mostly Pakistan on mobile data; under 200 pages and about 2 GB of images and PDFs in year one; enquiries under 5,000 a year. Validate with analytics in the first intake and with admissions' records (OD-13).

B. Application shape & components

06. What are the main components, and what responsibility does each own?

> See the Component & integration inventory and diagram at the end. In short: static host and CDN (serve pages), Git repository (source of truth), Git-based CMS (editing), enquiry function (accept enquiries safely), Google Sheet (enquiry store and status), email service (notifications), spam check, DNS, analytics, uptime monitor, backups.

07. How do requests and data move between browser, server, database, file storage and external systems?

> 1. Visitor's browser → DNS → static host/CDN → cached HTML, images, PDFs.
> 2. Enquiry: browser → spam check (token) → enquiry function → validates, rate-limits → appends a row to the Google Sheet → sends email to admissions and auto-reply → returns success → browser shows Thank-you.
> 3. Staff edit: browser → CMS → commits files to the Git repository → host builds → new version deployed atomically.
> 4. Admissions: browser → Google Sheet (filter, status, export).
> 5. Analytics events: browser → analytics (event names only).

08. Which features need real-time updates, queues or scheduled work, and why?

> Real-time: none. Queues: none in release 1 (volume is low; failures are shown to the visitor). Scheduled: daily rebuild so intake badges and notice archiving follow dates (SRS E-07); weekly backup export; optional 9 am enquiry summary (SRS I-04).

09. What can fail independently, and what should users experience when a component is unavailable?

Fails	User experience
Enquiry function or sheet	Pages work; form shows failure with WhatsApp and phone
Email service	Enquiry still stored; admissions checks the sheet
CMS or build	Live site unchanged; staff cannot publish until fixed
Spam check	Form falls back to honeypot + rate limit
Maps, YouTube, analytics	Text fallbacks; no visible effect for analytics
Host/CDN	Holding page or previous deploy (RTO 4 h)

10. Which parts should be replaceable without rewriting the whole website?

Host (output is plain files), CMS (content is plain files), enquiry store (function writes through one small adapter, so the sheet can become a database later), email provider, spam check and analytics (configuration only).

C. Platform & delivery choices

11. Which frontend, backend and CMS options meet the actual requirements and team's maintenance capacity?

Frontend: a static site generator producing semantic HTML with minimal JavaScript (ADR-02). Backend: one serverless function, JavaScript (ADR-05). CMS: a Git-based editor (ADR-03). All fit one developer who already works in VS Code. Rejected for release 1: WordPress (patching burden, previous compromise), a custom server application (more to secure and host).

12. What hosting region, provider and environment separation are needed, and what drives those choices?

Provider **Not Decided** (OD-03). A global CDN serving from locations near Pakistan matters more than a single region; check edge presence in Pakistan before choosing. Environments: local development, password-protected staging (proposed staging.rips.edu.pk), production — separate keys, separate sheet and test mailbox for staging (SRS S-01, S-02).

13. What are the build, deployment, rollback and configuration-management steps for each environment?

1. Developer works on a branch locally; checks run (links, accessibility, HTML).
2. Push to the staging branch → host builds and deploys staging automatically.
3. Review on staging; approval per SRS T-09.
4. Merge to main and tag the release → production build and atomic deploy.
5. Rollback: restore the previous deploy from the host dashboard (minutes) or revert the commit; holding page within 30 minutes if needed (SRS S-07).
6. Configuration (keys, mailbox addresses, sheet ID) lives in each environment's host settings, never in the code.

14. How will secrets, API keys and environment settings be stored, rotated and kept out of source code?

> Stored as encrypted environment variables in the host settings, one set per environment. Repository ignores local .env files and has secret scanning switched on. A copy of each credential sits in an institute-owned password manager with two named owners. Rotated yearly, after any staff departure with access, and immediately after any suspected leak.

15. Which domains, certificates, email services or DNS changes must be arranged before launch?

> - Record current DNS and MX records at DOMAIN.pk before touching anything.
> - Point rips.edu.pk and www to the new host; add staging subdomain.
> - HTTPS certificates (issued automatically by the host).
> - Mail records for the chosen email provider plus SPF, DKIM, DMARC.
> - Registrar lock and two-factor on the DOMAIN.pk account; renewal date checked.
> - Verify the domain in Search Console.

D. Data, files & integration

16. What information must persist, for how long, and which component is its source of truth?

Information	Source of truth	Retention (SRS M-05)
Pages, programs, fees, notices, PDFs, images	Git repository	While relevant; notices 2 years
Content history and who changed it	Git history	Permanent
Enquiries, statuses, notes	Google Sheet	12 months after intake (proposed)
Analytics	Analytics service	14 months
Function and host logs	Host	90 days

17. What backup, restore and data migration approach is needed for a real loss or schema change?

> Repository: hosted copy plus a weekly mirror to institute storage; any version can be redeployed. Sheet: built-in version history plus a weekly export. Restore drill before launch and every 6 months (SRS P-10). Schema changes to the sheet (new column) are added at the right edge so existing rows stay valid. No migration from the old site (SRS M-09).

18. Which files are uploaded or generated, and how are size, type, access and retention controlled?

> Staff upload PDFs (≤5 MB) and images (compressed to about 1 MB) through the CMS into the repository; type checked by the CMS settings and the build. Build generates resized images, sitemap and sharing images. All files are public by design; merit-list PDFs get a no-index header. No visitor uploads in release 1. Old files leave the site with their notice after 2 years.

19. Which external APIs or vendors are involved, and who owns credentials, contracts and outages?

> Host, Git provider, CMS sign-in, Google (Sheets, Analytics, Search Console, Maps, YouTube), email provider, spam check, uptime monitor, WhatsApp. The institute owns every account; the developer manages them; outages are handled per the inventory (SRS J-08).

20. How are retries, duplicate requests, timeouts and inconsistent external responses handled?

> Each form carries a one-time token; the function rejects a reused token as a duplicate (SRS Q-03). The function waits up to 10 s for the sheet and retries once; the browser gives up at 15 s and shows the failure message. Same phone and program within 7 days is flagged, not rejected. Any unexpected reply is treated as failure, never as success (SRS Q-07).

E. Identity & security

21. How do users authenticate, regain access and end a session across devices?

> Visitors: no authentication. Staff: sign in to the CMS through the Git provider and to the sheet through Google, both with two-factor enforced for the institute's organisation. Password recovery uses those providers' own processes. Sessions end on sign-out or provider timeout; the administrator can revoke access centrally. The exact SRS C-08/C-09 behaviour depends on these providers and is confirmed in the ADR-03 trial.

22. Where is authorization checked for each protected operation and data item?

> Content changes: Git provider repository permissions plus the CMS review workflow. Enquiry data: Google Sheet sharing (admissions and administrator only). Enquiry function: accepts only new enquiries — it has no read operation, so it cannot leak records. Nothing protected is served by the static host.

23. What are the main threats: account takeover, injection, exposed files, abuse or data leakage?

Threat	Main control
Takeover of registrar, Git, Google or host accounts	Two-factor everywhere, few administrators, registrar lock, change alerts
Injection via the form (email HTML, spreadsheet formulas)	Strict validation, escaping in emails, prefix values starting with = + - @ so the sheet never runs them
Exposed secrets or files	No secrets in code, secret scanning, only intended files published
Spam and abuse	Invisible CAPTCHA, honeypot, rate limit 5/hour/device
Data leakage	Sheet shared narrowly; no personal data in analytics or logs; exports confirmed
Site defacement	No server to compromise; deploys only from the repository

24. What protections are needed for transport, stored sensitive data, logs and administrative access?

> HTTPS only with HSTS, TLS 1.2+; security headers including a content security policy; enquiry data stored only in the institute's Google account; logs record outcome and error type but no names, phone numbers or messages; administrative access limited to named people with two-factor and reviewed every quarter.

25. What is the process for dependency updates, vulnerability response and security incident handling?

> Automated dependency update requests reviewed monthly; build-time dependencies only, so most issues never reach visitors. Critical vulnerabilities in the function patched within 2 working days. Incidents follow SRS O-12: holding page, rotate keys, check DNS, restore, inform the Director, notify people if data was exposed.

F. Performance, resilience & observability

26. What measurable targets exist for page load, key operations, availability and recovery?

> LCP ≤ 2.5 s on mid-range Android over 4G; page weight ≤ 1.5 MB; enquiry under 5 s (95%); staff changes live in 5 minutes; availability 99.5% monthly; RTO 4 h, RPO 24 h for content and zero loss of stored enquiries (SRS P-03 to P-07; NFR table in Doc 03).

27. What caching or content-delivery approach is appropriate, and when must cached data be invalidated?

> All pages, images and PDFs served from the CDN. Each deploy replaces the cache for changed files. Images and scripts with versioned names can be cached for a year; HTML and PDFs for a short time (minutes) so replaced merit lists show quickly. The enquiry function is never cached.

28. How will the system behave under traffic spikes, slow networks and partial outages?

> Spikes (merit lists): static files from the CDN scale without servers; only the form has limits, protected by rate limiting. Slow networks: light pages, text first, lazy images. Partial outages: as Q09 — reading always works even if forms or editing fail.

29. What logs, metrics, traces and alerts will show failures without exposing personal data?

> Function logs: time, outcome, error type, duration — no field values. Metrics: enquiries per day, failure count, uptime, Core Web Vitals from analytics, Search Console errors. Alerts: site down 5 minutes, 3 form failures in an hour, certificate or domain expiry, DNS change, failed backup (SRS R-06).

30. Who investigates an incident, and what runbook or escalation path is needed?

> The developer investigates; the Director is told the same day for anything visible to the public or involving personal data. Runbook covers: switch on holding page, roll back a deploy, restore the sheet, rotate keys, re-point DNS, unlock staff, contact host and registrar support (SRS S-06, S-08).

G. Quality & maintainability

31. Which automated checks cover critical journeys, permissions, integrations and failure paths?

> On every build: HTML validity, broken links, accessibility scan, page-weight budget. Automated browser tests (e.g. Playwright) for J1–J3 on staging: submit enquiry, error messages, double submit, function failure (simulated), filters. Function unit tests for validation, token reuse, duplicate flag and formula escaping. Permissions are checked manually each release because they live in external services.

32. How will accessibility and cross-browser behavior be checked in the release process?

> Automated accessibility scan in the build; manual keyboard and screen-reader spot checks before each release with visible changes; browser matrix from SRS N-01 tested on staging before go-live; Lighthouse on the four key pages.

33. What development, staging and production test data are safe to use, and how are they isolated?

> Only fictional data (“Test Student One, 0300 0000001”). Staging has its own sheet, test mailbox, keys and spam-check site; staging is password-protected and not indexed. No production enquiries are copied to staging or to the developer’s computer.

34. What documentation must another maintainer have to operate, debug and extend the site?

- README: how to run, build and deploy.
- Architecture diagram and this decision register.
- Content model (Doc 08) and CMS configuration notes.
- Runbook (Q30) and account list with owners (no passwords).
- Redirect list and sitemap rules.
- Staff guides (SRS S-06).

35. What are the expected ongoing costs, usage limits and vendor lock-in risks of the preferred design?

Expected costs: domain renewal; email mailboxes (OD-04); optional paid tiers only if limits are reached; optional photography. Host, CMS, spam check, analytics, uptime and Google Sheets can likely run on free tiers at this traffic — **check each plan's limits** (bandwidth, function calls, form volume, staging protection). Exact amounts: **Not Decided** (OD-12). Lock-in: low; pages are plain files and content is plain files in Git.

H. Decision & acceptance

36. Which major choices need a written decision comparing options, evidence and consequences?

ADR-01 to ADR-09 in the Architecture decision register at the end: site type, generator, editing tool, hosting, enquiry handling, email, spam protection, analytics, staff identity.

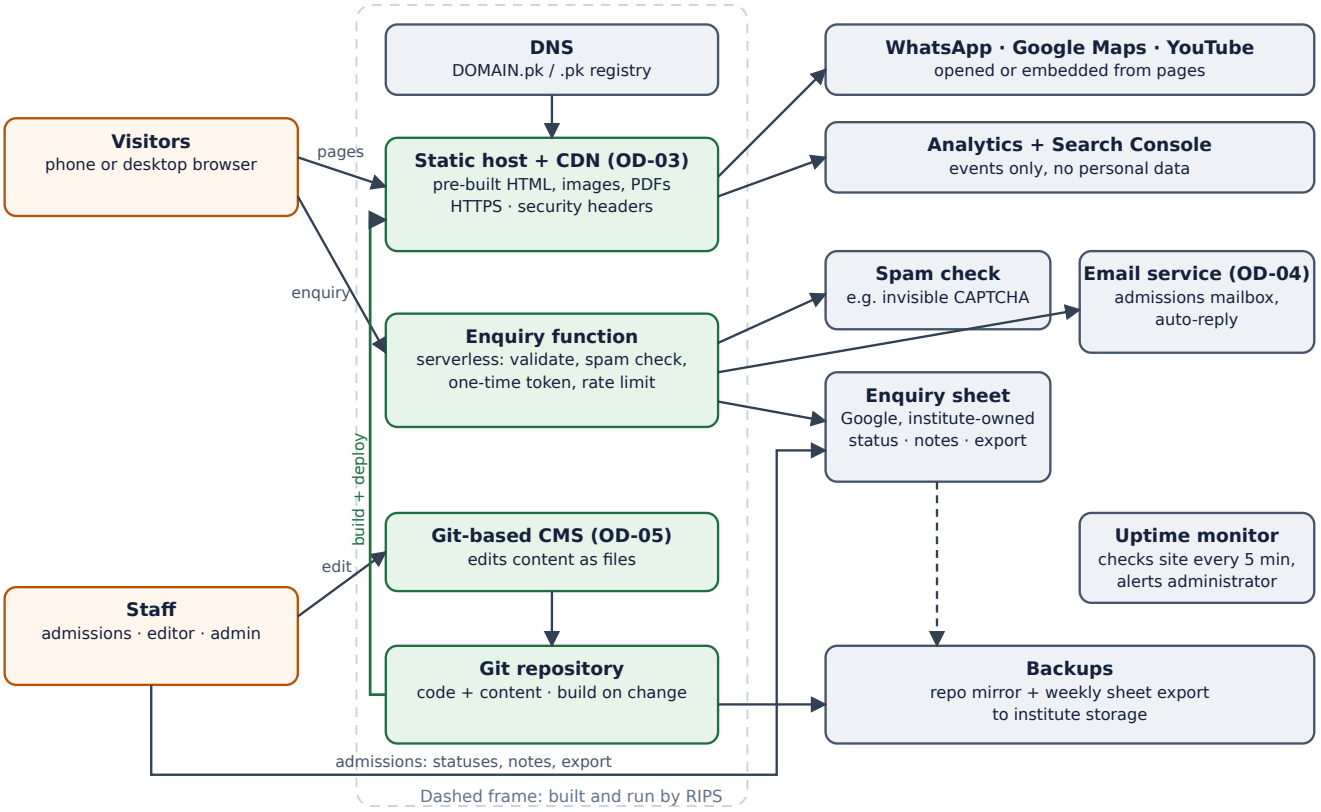
37. Which proposed choices depend on an owner, legal, budget or provider decision?

Choice	Depends on
Hosting (ADR-04)	Budget OD-12; provider plan limits
Email (ADR-06)	Director; budget; existing mailboxes
Editing tool (ADR-03)	Trial result; Director's acceptance of per-type permission limits
Analytics (ADR-08)	Legal review OD-15 on consent
Enquiry store in Google (ADR-05)	Legal review OD-15 on where personal data may be kept

38. What diagram, deployment demonstration and failure-recovery evidence will show this architecture is ready to build or run?

- Component diagram (end of this document).
- Staging deploy from a commit, then production deploy, shown to the Director.
- Rollback rehearsal: restore previous deploy in under 15 minutes.
- Enquiry test end to end, plus a simulated function failure.
- Backup restore of repository and sheet to staging.
- Security scan and SSL report (SRS T-05).

Architecture diagram (proposed)



Solid arrows: requests and data. Dashed arrow: backup. Green boxes are built and run by RIPS; grey boxes are external services the institute holds accounts for. Decisions marked OD and ADR are still open.

Architecture decision register

ID / topic	Options & evidence	Chosen option / status	Owner / date	Consequence / review trigger
ADR-01 Site type	A) static site + Git-based CMS + external form handling; B) hardened WordPress on managed hosting; C) custom app with database. Evidence: content-centred site, low traffic (SRS P-01), one developer, previous WordPress compromise, low budget.	A — **Proposed**	Developer; Director approves	No server or database to patch; enquiry tracking lives outside the site. Review if logged-in student features (phase 3) are approved.
ADR-02 Site generator	Eleventy, Astro, Hugo or hand-written HTML. All output plain HTML. Eleventy and Astro fit a JavaScript developer in VS Code.	**Not Decided** — decide after a 1-day trial	Developer	Changing later means re-templating, not re-writing content.
ADR-03 Content editing (OD-05)	Git-based editors (e.g. Decap CMS, Pages CMS) vs editing files on GitHub. Need: drafts, review, simple forms for notices, image upload.	**Not Decided** — Git-based CMS preferred	Developer; Director approves	Per-type permissions (merit lists only by admissions) must be checked in the trial; if unsupported, enforced by review process.
ADR-04 Hosting (OD-03)	Static hosts with global CDN and free tiers (e.g. Cloudflare Pages, Netlify, Vercel) vs shared hosting. Need: HTTPS, preview builds, instant rollback, serverless functions, good speed in Pakistan.	**Not Decided**	Director with developer	Check plan limits, function support, edge presence in Pakistan, password protection for staging.
ADR-05 Enquiry handling (OD-06)	A) hosted form service; B) small serverless function writing to an institute Google Sheet and sending email. SRS needs one-time tokens, duplicate flag, statuses, export.	B — **Proposed**; A as fallback	Developer	Sheet gives admissions familiar filters, status dropdown, version history and sharing-based access. Review if volume exceeds ~20,000 rows a year.
ADR-06 Email (OD-04)	Google Workspace, Zoho Mail or host email for mailboxes; a transactional email service or the mailbox provider for auto-replies.	**Not Decided**	Director with developer	MX records must be recorded before any DNS change; SPF, DKIM, DMARC required.
ADR-07 Spam protection	Invisible CAPTCHA (e.g. Cloudflare Turnstile, hCaptcha) vs Google reCAPTCHA vs honeypot only.	Invisible CAPTCHA + honeypot + rate limit — **Proposed**	Developer	Must stay keyboard and screen-reader friendly.
ADR-08 Analytics	Google Analytics 4 (as PRD and SRS state) vs cookieless analytics (no consent banner needed).	GA4 as agreed; cookieless option to be raised with Director	Director	If cookieless is chosen, SRS O-08 cookie banner can be dropped — record as a change.
ADR-09 Staff identity	Sign-in through the CMS's Git provider (with enforced two-factor) and Google accounts (2-step verification) for the sheet.	**Proposed**, depends on ADR-03	Developer	Staff need accounts on those services; offboarding removes access in both.

Assumptions and decisions still blocked	• Traffic and volume assumptions (Q05) until the first intake's data. • Budget (OD-12) for email and any paid tiers. • Legal review (OD-15) on consent and where enquiry data may be stored. • Trial of the editing tool (ADR-03) for permissions and two-factor.

Component & integration inventory

Component / service	Purpose / data	Owner / credentials	Failure / retry behaviour	Cost / limit / status
Static host + CDN	Serves all pages and PDFs	Institute account; developer manages	Cached pages keep serving; rollback to previous deploy	Free tier likely enough; check bandwidth · OD-03
Git repository	Source of truth for code and content	Institute organisation; 2 owners	Mirror copy weekly	Free · Proposed
Git-based CMS	Staff editing, drafts, review	Staff sign in via Git provider	If down, developer edits files directly	Free (open source) · OD-05
Enquiry function	Validate, spam check, token, write sheet, send email	Code in repo; keys in host settings	Visitor sees failure + WhatsApp; alert after 3 failures/hour	Within free function limits · Proposed
Google Sheet	Enquiry store, statuses, notes, export	Institute Google account; admissions + admin only	Function retries once; otherwise email still sent	Free · Proposed
Email service	Admissions mailbox, auto-replies, alerts	Institute account	Enquiry still stored if email fails	OD-04
Spam check	Bot protection on forms	Institute account; site + secret key	Falls back to honeypot + rate limit	Free · Proposed
DNS (DOMAIN.pk)	Domain and records	Institute; 2 named people; registrar lock	Change alerts to 2 people	Yearly renewal
Analytics, Search Console	Measurement, search health	Institute Google account	No user impact	Free
Maps, WhatsApp, YouTube	Directions, chat, video	Institute accounts / number	Text fallbacks (SRS J-05)	Free
Uptime monitor	Downtime and certificate alerts	Institute account	—	Free tier
Backups	Repo mirror, weekly sheet export	Institute storage	Restore drill every 6 months	Free / existing storage

Diagram, recovery and monitoring notes	Diagram on the previous pages. Recovery: previous deploy or holding page (30 min), sheet version history, weekly exports. Monitoring: uptime every 5 minutes, function failure alerts, Search Console weekly.